BELEQET · PROGRESS REPORT · 4 NOVEMBER 2026

Automatic deploys, an outage, and Telegram security

Everything since the last report ("Admin rebuild, launch and post-launch fixes").

Status:

- **Deploys are automatic.** Every merge to `main` now goes to production by itself once CI passes, with backups and automatic rollback.
- **A critical account-takeover hole was found and closed.** It was found while answering the CTO's question about posting from Telegram.
- **Posting jobs from inside the Telegram bot now works.** It was merged today and is deploying.
- **The server's exposed databases are still the most urgent open item** (section 8).

1. Post-launch fixes are live

The `fix/post-launch` branch from the last report was merged and deployed with the new deploy script. It contained:

- the job-application page;
- the "create employer account" fix;
- the Telegram conflict fix;
- the CI/CD fixes.

The bot security fixes are in the repository. They go live on the bots together with the Mini App update (section 8).

2. Every job is applied for on Beleqet

Many jobs sent applicants to the company's own website or email. Now every job is applied for on Beleqet, on the new apply page (#241):

- **Job pages:** the external "Apply on company site" and "Apply by email" options are gone.
- **Post-a-job form:** it no longer asks how to receive applications.
- **Employers who want applications elsewhere:** Beleqet staff forward the applications to them.

3. Automatic deploys

Production used to be updated by hand. Now (#242):

1. A merge to `main` runs CI.
2. When CI passes, GitHub connects to the server and runs the deploy script.
3. The script:
   - backs up the database;
   - pulls the images CI built and tested;
   - applies database migrations;

- switches over;
- checks the site is healthy;
- rolls back by itself if not.

Setup problems, now fixed:

- **Secrets:** two GitHub secrets contained a stray line break, which made the deploy fail (#244). The deploy now ignores stray whitespace.
- **Unused secrets:** the old staging secrets were identified for removal.

First successful automatic deploys: `e848506` and `4e3c639`, both on 4 November.

Staging: the "Deploy Staging" workflow no longer runs by itself. A real staging server is still to be decided (section 8).

4. Incident: full disk and a public crash alert

> **What happened:**
> - **The disk filled up.** Each deploy downloads about 4 GB of new images, and old ones were never removed. The server's disk reached **100%**.
> - **The database and API failed.** The database could no longer write and stopped. The API then returned errors.
> - **Alerts reached the public channel.** The API's crash alerts were set to post to the **public jobs channel**, so subscribers saw technical error messages.

Recovery:

- Space was freed: old images, system logs and the package cache.
- The database and API were restarted and recovered.
- All **21 alert posts** were deleted from the channel.

Prevention (#243, live):

Change	Effect
Crash alerts	They go only to a private alert chat, never the public channel, and at most once every 10 minutes per page. Until the private chat is set, no alerts are sent.
Deploy script: old images	Removes old images before downloading new ones, and again after a successful deploy. It keeps one rollback version.
Deploy script: free space	Stops, changing nothing, if less than 5 GB would be free.
Backups	Keeps the 10 newest automatic backups. Hand-made backups are never touched.

Disk now: 4.2 GB free (89% used). This is still tight for a 38 GB disk.

5. Critical: account takeover through the Telegram bot

The CTO asked whether jobs can be posted from the Telegram bot. Checking this showed that the API endpoints used by the Jobs bot were **public**, with no password or secret. Anyone on the internet could:

What an outsider could do	Severity

Take over any account, knowing only its email address: "register" with the victim's email (the reply revealed the account's internal ID), link their own Telegram to that ID, then sign in through Telegram as the victim. This was proven on a local copy, not on real accounts.	Critical
Download the Telegram IDs of all registered users	High
Check whether an email or Telegram account is registered; create accounts in bulk	High
Call the payment-status and language endpoints. These only write a log line today and change nothing, but they would have been open the day they were made to do something.	Low

Response, all on 4 November:

- **Within the hour:** the server's web gateway (nginx) blocked these endpoints from the internet.
- **Fix (#245, live):**
  - The endpoints now require a secret that only the Jobs bot has.
  - Registering through the bot can no longer reach an existing account.
  - The insecure "link by ID" feature was removed.
- **Verified on production:**
  - requests without the secret are refused;
  - the Jobs bot is accepted with it;
  - all bots are running without errors.

  The nginx block stays as a second layer.

Recommended follow-up: check the server logs for past use of the "link-telegram" endpoint to see whether the hole was ever abused.

6. Posting jobs from inside Telegram

Answer to the CTO's question.

- **Posting on the website** already sent the job to the Telegram channel automatically. This was tested with a test channel.
- **Posting from inside the bot** did **not** work:
  - the bot's "Post Job" button opened the website's sign-in page;
  - employers registered through the bot have no password.

Built (#246, merged, deploying now):

- **No password needed:** when the website is opened from the bot, it signs the employer in with Telegram's own signed proof of who they are.
- **Accepts the Jobs bot:** the API now recognises the Jobs bot's signature. Before, it only recognised a different bot's, so this could never have worked.
- **Safeguards:**
  - admins still sign in with their password;
  - accounts with two-step sign-in still enter their code;
  - other bots are refused.

Tested end to end on a local copy, from bot registration to sign-in, company profile and the published job ("Your job is live"). **Still to do:** confirm it in the real bot once the deploy finishes.

7. Credentials check

The server's settings were reviewed. Values were not read or shared, only whether each one is set.

Setting	State
Two-step sign-in secret, unsubscribe-link secret	**Placeholder** to be generated
Privacy salt (`PII_SALT`)	**Empty** falls back to a default; changing it needs care, because existing data depends on it
API mode	**Development** the settings file says production, but the server's compose file overrides it
API documentation page (Swagger)	**Public** lists every endpoint to anyone
Chapa	Test keys
PayPal, Google and LinkedIn sign-in	Dummy or placeholder values
OpenAI / Groq (AI features)	Missing
File storage (R2)	Missing
Private alert chat	Not set
Promo bot	Runs on a separate server (163.192.222.65), which is unreachable. Its owner and Telegram username are unknown.

8. Open items

> **Most urgent, unchanged since the last report: exposed databases.** These are still reachable from the internet, checked today:
> - the **Beleqet Pay database** (port 5433);
> - its **Redis** (6381);
> - **Adminer**, a database admin page (8081);
> - **Qdrant** (6333).
>
> They should be limited to the server itself. Then change the database password, which is stored in plain text on the server.

Item	Who
Confirm "Post Job" works in the real Jobs bot after today's deploy	Team
Create a private Telegram chat for crash alerts and add the alert bot to it	CTO
Generate the placeholder secrets; switch the API to production mode; hide the public API documentation	Dev, with approval
Two bots (Academy, Share-and-Win) write their tokens into the server logs. Fixed in the repository; once the new bot code is live, issue new tokens with @BotFather	Bot owner
Bots go live together with the Mini App update: each Mini App must send `X-Telegram-Init-Data` ; decide `TRANSFER_SECRET_KEY` with the Promo bot owner	Mini App owner, CTO

GitHub cleanup: delete the old `STAGING_*` secrets, revoke the old GHCR token, remove the spare deploy key from the server	Repo owner
Check the logs for past abuse of the account-takeover hole (section 5)	Dev
Disk is 89% full with 4.2 GB free: enlarge the disk or move Beleqet Pay or voice-ai to another server	CTO / Ops
A real staging server, separate from production	CTO
Still pending: live PayPal and Chapa credentials, AI and storage keys, bank transfer details, confirming the 2 admin accounts, native Amharic review	CTO / content